



FFIEC Information Technology Examination Handbook

Business Continuity Management

NOVEMBER 2019

Contents

INTRODUCTION.....	1
I BUSINESS CONTINUITY MANAGEMENT	2
II BUSINESS CONTINUITY MANAGEMENT GOVERNANCE.....	3
II.A Board and Senior Management Responsibilities	4
II.B Audit	6
III RISK MANAGEMENT.....	7
III.A Business Impact Analysis	9
III.A.1 Identification of Critical Business Functions	10
III.A.2 Interdependency Analysis	10
III.A.3 Impact of Disruption	11
III.B Risk Assessment.....	12
III.B.1 Risk Identification	13
III.B.2 Likelihood and Impact	14
IV BUSINESS CONTINUITY STRATEGIES	16
IV.A Resilience	18
IV.A.1 Physical	19
IV.A.2 Cyber Resilience	19
IV.A.3 Data Backup and Replication	19
IV.A.4 Personnel	21
IV.A.5 Third-Party Service Providers.....	22
IV.A.6 Telecommunications	23
IV.A.7 Power	24
IV.A.8 Change Management.....	24
IV.B Communications	25
V BUSINESS CONTINUITY PLAN	26
V.A Event Management.....	27
V.B Continuity and Recovery	28
V.C Facilities and Infrastructure	29
V.C.1 Data Center Recovery Alternatives	29
V.C.2 Branch Relocation	30
V.D Payment Systems.....	31
V.E Liquidity Considerations	31
V.F Other Components.....	31
V.F.1 Incident Response.....	32

V.F.2	Disaster Recovery	33
V.F.3	Crisis or Emergency Management	34
VI	TRAINING	35
VII	EXERCISES AND TESTS	37
VII.A	Exercise and Test Program	38
VII.B	Exercise and Test Policy	39
VII.C	Exercise and Test Strategies.....	39
VII.D	Exercise and Test Objectives.....	40
VII.E	Exercise and Test Plans	40
VII.F	Exercise and Test Scenarios.....	41
VII.G	Exercise and Test Methods	42
VII.G.1	Full-Scale Exercise.....	42
VII.G.2	Limited-Scale Exercise	43
VII.G.3	Tabletop Exercise.....	43
VII.G.4	Tests	44
VII.H	Industry Exercises and Resilience	44
VII.I	Third-Party Service Provider Testing	45
VII.J	Testing for Core and Significant Firms	45
VII.K	Post-Exercise and Post-Test Actions	46
VIII	MAINTENANCE AND IMPROVEMENT	47
IX	BOARD REPORTING	49
APPENDIX A:	EXAMINATION PROCEDURES	50
APPENDIX B:	GLOSSARY	70
APPENDIX C:	ABBREVIATIONS.....	77
APPENDIX D:	REFERENCES.....	78

Introduction

The “Business Continuity Management” (BCM) booklet is one in a series of booklets that comprise the *Federal Financial Institutions Examination Council (FFIEC)*¹ *Information Technology Examination Handbook (IT Handbook)*. The *IT Handbook* is prepared for use by examiners.² With the publication of this booklet, the FFIEC member agencies replace the “Business Continuity Planning” booklet issued in February 2015. The change from business continuity planning to business continuity management reflects the changes in customer and industry expectations for the resilience of operations.

The BCM booklet describes principles and practices for IT and operations for safety and soundness, consumer financial protection, and compliance with applicable laws and regulations. The BCM booklet also outlines BCM principles to help examiners evaluate how management addresses risk related to the availability of critical financial products and services. This booklet discusses BCM governance and its related components, including resilience strategies and plan development; training and awareness; exercises and tests; maintenance and improvement; and reporting for all levels of management, including the board of directors.

The focus of this revised booklet is on enterprise-wide, process-oriented approaches that consider technology, business operations, testing, and communication strategies critical to the continuity of the entire entity. However, business continuity should not be focused only on the planning process to recover operations after an event, but rather it should include the continued maintenance of systems and controls for the resilience of operations. Business continuity should be incorporated into the risk management life cycle of all systems, processes, and operations of an entity.

For *IT Handbook* purposes, the term “entities” includes depository financial institutions,³ nonbank financial institutions,⁴ bank holding companies,⁵ and third-party service providers.⁶

¹ The FFIEC was established on March 10, 1979, pursuant to Title X of the Financial Institutions Regulatory and Interest Rate Control Act of 1978, Pub. L. 95-630. The FFIEC members include the Board of Governors of the Federal Reserve System (FRB), the Consumer Financial Protection Bureau (CFPB), the Federal Deposit Insurance Corporation (FDIC), the National Credit Union Administration (NCUA), the Office of the Comptroller of the Currency (OCC), and the State Liaison Committee (SLC).

² Each FFIEC member agency may use the principles outlined in this booklet, consistent with the member agency’s supervisory authority.

³ The term “depository financial institution” includes national banks, federal savings associations, state savings associations, state member banks, state nonmember banks, and credit unions.

⁴ The term “nonbank financial institution” includes non-depository financial institutions under CFPB’s jurisdiction and subject to CFPB supervision and examination.

⁵ The term “bank holding company” includes any company which has control over any bank or over any company that is or becomes a bank holding company as defined by the Bank Holding Company Act.

⁶ The term “third-party service providers” includes those entities that provide banking services subject to examination under the Bank Service Company Act, the Home Owners Loan Act of 1933, the Dodd-Frank Wall Street Reform and Consumer Protection Act, or other relevant law.

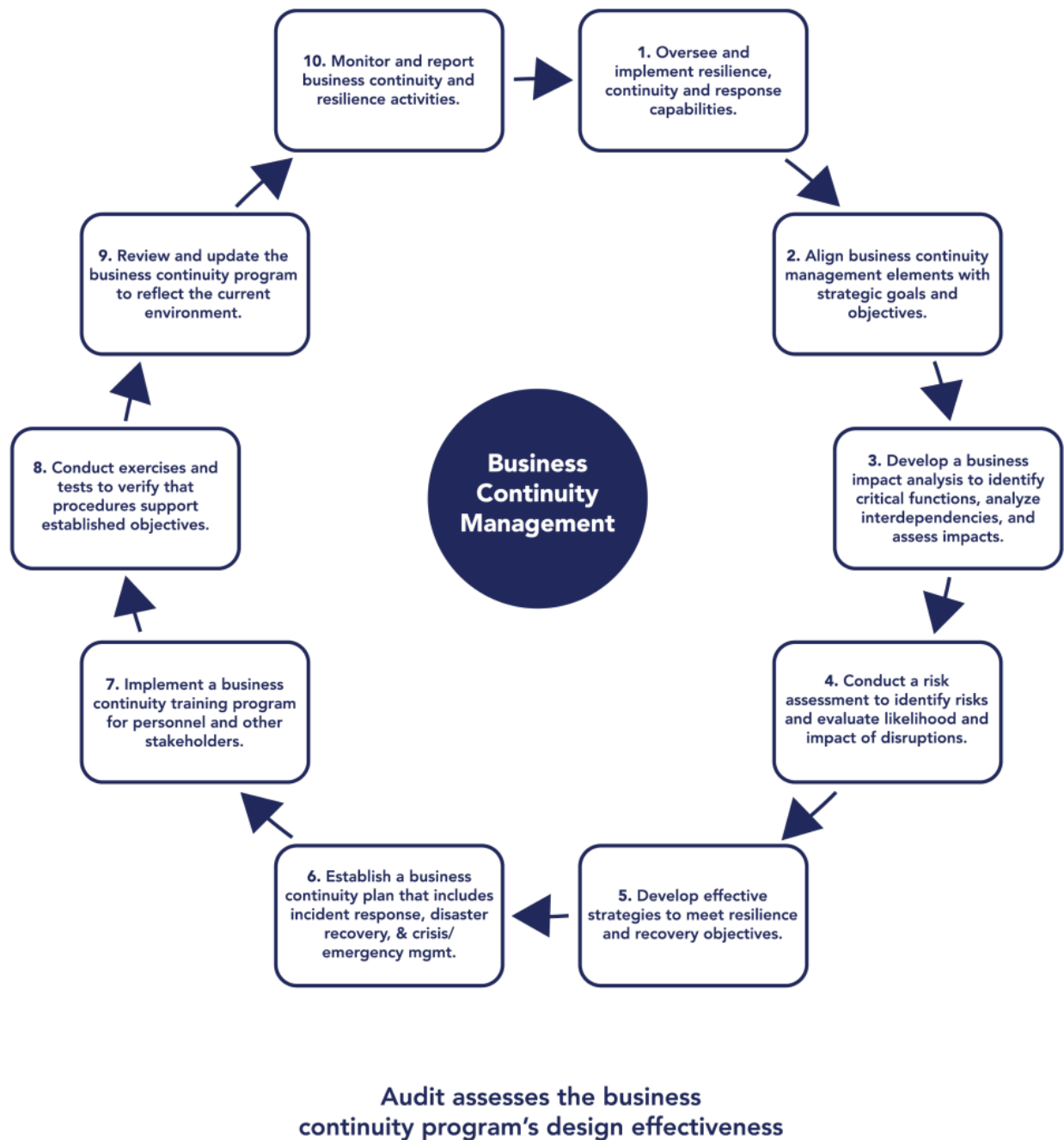
This booklet does not impose requirements on entities. Instead, this booklet describes practices that examiners may use to assess an entity's BCM function.

Appendix A of this booklet provides objectives-based examination procedures. The application of the principles and related examination procedures should vary according to an entity's complexity and risk profile. Examiners should evaluate entities in accordance with their agency's regulatory authority.

I Business Continuity Management

BCM is the process for management to oversee and implement resilience, continuity, and response capabilities to safeguard employees, customers, and products and services. Disruptions such as cyber events, natural disasters, or man-made events can interrupt an entity's operations and can have a broader impact on the financial sector. Resilience incorporates proactive measures to mitigate disruptive events and evaluate an entity's recovery capabilities. An entity's BCM program should align with its strategic goals and objectives. Management should consider an entity's role within and impact on the overall financial services sector when it develops a BCM program.

Figure 1: Business Continuity Management Cycle



II Business Continuity Management Governance

This section provides specific information about BCM governance, including board and senior management responsibilities. General information about governance and risk management is contained in the *IT Handbook's* "Management" booklet and the FFIEC members' examination handbooks.

BCM governance should include:

- Aligning BCM practices with the risk appetite.
- Identifying the continuity level needed, consistent with the operation's criticality.
- Establishing business continuity policy and plans.
- Allocating resources to BCM activities.
- Providing competent management to implement the program.
- Monitoring and assessing business continuity performance relative to these goals.

Figure 1 depicts a typical BCM cycle that entities may follow to manage business continuity risks on an ongoing basis. To manage these risks, the entity may develop a single encompassing BCM policy or individual policies and plans for different functions, depending on the size and complexity of the entity's operations. An effective practice for business continuity-related policies is to address, at a minimum, the following areas: scope and responsibilities within BCM, accountability, authority, and guidance to develop and maintain effective BCM.

II.A Board and Senior Management Responsibilities

Action Summary

The board and senior management govern business continuity through defining responsibilities and accountability, and by allocating adequate resources to business continuity.

Examiners should review for the following:

- Alignment of BCM elements with the entity's strategic goals and objectives.
- Board oversight.
- Management assignment of BCM-related responsibilities.
- Development of BCM strategies.

The board⁷ and senior management should set the “tone at the top” and consider the entity's entire operations, including functions performed by affiliates and third-party service providers, when managing business continuity. Management should evaluate continuity risk, set short- and long-term continuity objectives, adopt policies and procedures to mitigate continuity risk, evaluate continuity performance, and adjust operations in response to test results and actual events.

Management can strengthen resilience by assessing risk, planning, testing the plans, and incorporating lessons learned from tests and events. Furthermore, management should consider resilience in business functions and the design of new products and services.

⁷ Most financial institutions have boards of directors; however, not all third-party service providers do. When an entity does not have a board, the senior leaders may have the responsibilities of the board described in this booklet.

Board oversight should include:

- Assigning BCM responsibility and accountability.
- Allocating resources to BCM.
- Aligning BCM with the entity's business strategy and risk appetite.
- Understanding business continuity risks and adopting policies and plans to manage events.
- Reviewing business continuity operating results and performance through management reporting, testing, and auditing.
- Providing a credible challenge⁸ to management responsible for the BCM process.

Management oversight should include:

- Defining BCM roles, responsibilities, and succession plans.
- Allocating knowledgeable personnel⁹ and sufficient financial resources.
- Validating that personnel understand their business continuity roles and responsibilities.
- Establishing measurable goals against which business continuity performance is assessed, such as levels of preparedness and resilience targets.
- Designing and implementing a business continuity exercise strategy.
- Confirming that exercises, tests, and training are comprehensive and consistent with the BCM strategy.
- Resolving weaknesses identified in exercises, tests, and training that exceed the entity's risk appetite.
- Meeting regularly with a designated coordinator or a business continuity committee to discuss policy changes, exercises, tests, and training plans.
- Assessing and updating business continuity strategies and plans to reflect the current business conditions and operating environment for continuous improvement.
- Coordinating plans and responses with external groups (as described in [IV.B, "Communications"](#)).

⁸ A credible challenge involves being actively engaged, asking thoughtful questions, and exercising independent judgment.

⁹ The term "personnel" includes both permanent and temporary staff.

II.B Audit

Action Summary

The board and senior management should engage internal audit or independent personnel to review and validate the design and operating effectiveness of the BCM program. Audit should report to the board and provide an assessment of management's ability to manage and control risks related to continuity and resilience.

Examiners should review the following:

- Scope of BCM-related audit activities.
- Audit reporting of BCM-related activities to the board.
- Board review of audit reports.
- Tracking and resolution of audit findings.
- Management's review of system and organization controls (SOC)¹⁰ and third-party service provider audit reports.

The board and senior management should engage internal audit (or an independent review) to assess the BCM design effectiveness, including policies and procedures, and the effectiveness of controls. Audit should report to the board and provide an assessment of management's ability to oversee and control risks related to continuity and resilience. Auditors should be qualified and independent of BCM processes. Audit scope and frequency depend on the entity's complexity, risk profile, and changes the entity may be experiencing. Large, complex entities may have multiple audits, covering various departments or aspects of the BCM program. Less complex entities may have their business continuity activities included within an IT general controls audit.

The internal audit of the BCM program should provide an independent assessment of management's ability to oversee the entity's continuity and resilience risk. Auditors should:

- Evaluate the business impact analysis (BIA) and risk assessment for reasonableness, identification of critical functions, and the likelihood of different events and the potential impact on operations.
- Evaluate controls for reliability, adequacy, and effectiveness regarding continuity and resilience.
- Leverage SOC reports and other external artifacts from third-party service providers, as appropriate.

¹⁰ "In 2017, the American Institute of Certified Public Accountants (AICPA) introduced the term "system and organization controls" (SOC) to refer to the suite of services practitioners may provide relating to system-level controls of a service organization and system- or entity-level controls of other organizations. Formerly, SOC referred to service organization controls. By redefining that acronym, the AICPA enables the introduction of new internal control examinations that may be performed (a) for other types of organizations, in addition to service organizations, and (b) on either system-level or entity-level controls of such organizations." (AICPA, [SOC 2 Examinations and SOC for Cybersecurity Examinations: Understanding the Key Distinctions.](#))

- Compare the entity’s inherent risk level and the effectiveness of risk mitigation against the entity’s risk appetite.
- Verify whether test plans achieve the stated objectives.
- Monitor BCM testing to verify that issues (e.g., deviation from test plans and failed objectives) are appropriately identified and escalated.
- Assess the BCM program’s effectiveness.

Refer to the *IT Handbook’s* “Audit” booklet for additional information.

III Risk Management

Business continuity risk management focuses on a subset of operational risk factors, against which capital and reserves alone may not protect an entity, and involves managing the possibility of an event that jeopardizes critical systems.¹¹ The BIA and risk assessment represent the foundation of BCM. As illustrated in figure 2, BCM should integrate with an entity’s enterprise risk management (ERM),¹² which allows for the identification and management of risk across the entire entity. BCM allows management to set strategy to effectively mitigate risks posed by disruptive events. The level and formality of BCM and ERM integration should be commensurate with the entity’s complexity and risk profile.

Figure 2: Business Continuity Management Elements (Relative to Enterprise Risk Management)



¹¹ Refer to the U.S. Department of the Treasury and the Department of Homeland Security’s (DHS) [Financial Services Sector-Specific Plan 2015](#).

¹² ERM is “[a] process, effected by an entity’s board of directors, management and other personnel, applied in strategy-setting and across the enterprise, designed to identify potential events that may affect the entity, and manage risk to be within the risk appetite, to provide reasonable assurance regarding the achievement of entity objectives.” (Committee of Sponsoring Organizations of the Treadway Commission (COSO), [Enterprise Risk Management – Integrated Framework \(Executive Summary\)](#), September 2004)